

AML / KYC - What Developers Need to Know

You are not compliance officers, but you implement controls they design.

Customer Due Diligence (CDD): identity verification, risk scoring, and periodic refresh. APIs must not bypass screening services.

Transaction monitoring: typologies (structuring, rapid movement) trigger alerts. Never log full PAN; use tokens.

Sanctions screening: OFAC/EU lists update frequently; batch and real-time calls must handle timeouts gracefully.

If you build onboarding flows, preserve audit trails: who changed risk level, when, and from which source system.